

API Documentation

Overview

Base URL: `http://localhost:5000` (development) | `https://api.example.com` (production)

Response Format: JSON

Authentication: Bearer token using JWT-based authentication with Spring Security

Rate Limits: 100 requests per minute

Authentication

Bearer Token

1. Obtain a token by logging in via the `/api/auth/login` endpoint with username and password.
2. Include the token in request headers: `Authorization: Bearer <token>`.
3. Token expires in 1 hour; refresh using the `/api/auth/refresh` endpoint.

Example Request with Auth

```
curl -X GET http://localhost:5000/api/expenses \
  -H "Authorization: Bearer your_token_here" \
  -H "Content-Type: application/json"
```

Endpoints

POST /api/expenses

Submit a new expense for approval.

Request:

- **Method:** POST
- **Path:** `/api/expenses`
- **Headers:** `Authorization: Bearer <token>`, `Content-Type: application/json`
- **Request Body:**

```
{
  "employeeId": "UUID, ID of the employee submitting the expense",
  "amount": "decimal, amount of the expense",
  "description": "string, description of the expense",
  "date": "string, date of the expense in YYYY-MM-DD format"
}
```

Response:

- **Status 201 (Created):**

```
{
  "success": true,
  "data": {
    "id": "UUID, ID of the submitted expense",
    "status": "string, status of the expense (SUBMITTED)"
  },
  "message": "Expense submitted successfully"
}
```

- **Status 400 (Bad Request):** Missing or invalid required field
- **Status 401 (Unauthorized):** Invalid or expired token
- **Status 500 (Server Error):** Unexpected error

Example:

```
curl -X POST http://localhost:5000/api/expenses \
-H "Authorization: Bearer token" \
-H "Content-Type: application/json" \
-d '{"employeeId":"123e4567-e89b-12d3-a456-426614174000","amount":100,"description":"Lun
```

GET /api/expenses

Retrieve all expenses submitted by employees.

Request:

- **Method:** GET
- **Path:** /api/expenses
- **Headers:** Authorization: Bearer <token>, Content-Type: application/json

Response:

- **Status 200 (OK):**

```
{
  "success": true,
  "data": [
    {
      "id": "UUID, ID of the expense",
      "employeeId": "UUID, ID of the employee who submitted the expense",
      "amount": "decimal, amount of the expense",
      "description": "string, description of the expense",
      "date": "string, date of the expense",
      "status": "string, status of the expense (SUBMITTED, APPROVED, REJECTED)"
    }
  ],
  "message": "Expenses retrieved successfully"
}
```

- **Status 401 (Unauthorized):** Invalid or expired token
- **Status 500 (Server Error):** Unexpected error

Example:

```
curl -X GET http://localhost:5000/api/expenses \
-H "Authorization: Bearer token" \
-H "Content-Type: application/json"
```

GET /api/expenses/{id}

Retrieve a specific expense by its ID.

Request:

- **Method:** GET
- **Path:** /api/expenses/{id}
- **Headers:** Authorization: Bearer <token>, Content-Type: application/json

Response:

- **Status 200 (OK):**

```
{
  "success": true,
  "data": {
    "id": "UUID, ID of the expense",
    "employeeId": "UUID, ID of the employee who submitted the expense",
    "amount": "decimal, amount of the expense",
    "description": "string, description of the expense",
    "date": "string, date of the expense",
    "status": "string, status of the expense (SUBMITTED, APPROVED, REJECTED)"
  },
  "message": "Expense retrieved successfully"
}
```

- **Status 401 (Unauthorized):** Invalid or expired token

- **Status 404 (Not Found):** Expense not found
- **Status 500 (Server Error):** Unexpected error

Example:

```
curl -X GET http://localhost:5000/api/expenses/123e4567-e89b-12d3-a456-426614174000 \
-H "Authorization: Bearer token" \
-H "Content-Type: application/json"
```

PUT /api/expenses/{id}/approve

Approve an expense by its ID.

Request:

- **Method:** PUT
- **Path:** /api/expenses/{id}/approve
- **Headers:** Authorization: Bearer <token>, Content-Type: application/json

Response:

- **Status 200 (OK):**

```
{
  "success": true,
  "data": {
    "id": "UUID, ID of the expense",
    "status": "string, status of the expense (APPROVED)"
  },
  "message": "Expense approved successfully"
}
```

- **Status 400 (Bad Request):** Invalid request
- **Status 401 (Unauthorized):** Invalid or expired token
- **Status 404 (Not Found):** Expense not found
- **Status 500 (Server Error):** Unexpected error

Example:

```
curl -X PUT http://localhost:5000/api/expenses/123e4567-e89b-12d3-a456-426614174000/approve \
-H "Authorization: Bearer token" \
-H "Content-Type: application/json"
```

PUT /api/expenses/{id}/reject

Reject an expense by its ID.

Request:

- **Method:** PUT
- **Path:** /api/expenses/{id}/reject
- **Headers:** Authorization: Bearer <token>, Content-Type: application/json

Response:

- **Status 200 (OK):**

```
{
  "success": true,
  "data": {
    "id": "UUID, ID of the expense",
    "status": "string, status of the expense (REJECTED)"
  },
  "message": "Expense rejected successfully"
}
```

- **Status 400 (Bad Request):** Invalid request
- **Status 401 (Unauthorized):** Invalid or expired token
- **Status 404 (Not Found):** Expense not found
- **Status 500 (Server Error):** Unexpected error

Example:

```
curl -X PUT http://localhost:5000/api/expenses/123e4567-e89b-12d3-a456-426614174000/reject
-H "Authorization: Bearer token" \
-H "Content-Type: application/json"
```

GET /api/expenses/report

Generate an expense report.

Request:

- **Method:** GET
- **Path:** /api/expenses/report
- **Headers:** Authorization: Bearer <token>, Content-Type: application/json

Response:

- **Status 200 (OK):**

```
{
  "success": true,
  "data": {
    "totalExpenses": "decimal, total amount of all expenses",
    "approvedExpenses": "decimal, total amount of approved expenses",
    "rejectedExpenses": "decimal, total amount of rejected expenses"
  },
  "message": "Expense report generated successfully"
}
```

- **Status 401 (Unauthorized):** Invalid or expired token
- **Status 500 (Server Error):** Unexpected error

Example:

```
curl -X GET http://localhost:5000/api/expenses/report \
-H "Authorization: Bearer token" \
-H "Content-Type: application/json"
```

Error Codes and Meanings

Status	Code	Meaning	When It Occurs
400	BAD_REQUEST	Invalid input	Submitting an expense with missing or invalid fields
401	UNAUTHORIZED	Invalid credentials	Token missing or expired
403	FORBIDDEN	Access denied	User lacks required role
404	NOT_FOUND	Resource not found	Expense or report not found
409	CONFLICT	Duplicate or state conflict	Record already exists
429	RATE_LIMIT	Too many requests	Exceeded rate limit
500	INTERNAL_ERROR	Server error	Unexpected error, check logs

Rate Limits and Quotas

- **100 requests per minute:** Exceeding this limit will result in a 429 RATE_LIMIT error.

Data Types and Formats

- **Timestamps:** ISO 8601 format (e.g., 2026-01-15T10:30:00Z)
- **Booleans:** true or false
- **IDs:** UUID v4 or numeric, as documented per entity
- **Enums:** Specific values listed in request/response examples

Pagination (if applicable)

This API does not support pagination.

SDK Examples

No SDKs are provided for this API.